Week 4 - AWS Resource Access Manager (RAM)

DOP-C02 Domains 2, 3 and 6. Typical questions:

1. A **central networking account** owns VPCs; app teams in other accounts **launch resources into those subnets** without peering or duplicate VPCs = **VPC sharing**.
2. **Every account** must attach to the **Transit Gateway** / use **Route 53 Resolver rules** / use the same **prefix lists** = **share with RAM to the org or OU**.
3. Share with all accounts **automatically, without invitations** = **enable sharing with AWS Organizations**, share to **org / OU**.
4. **Prevent** sharing **outside the organization** = **SCP on** `ram:RequestedAllowsExternalPrincipals` + `allowExternalPrincipals = false`.

The big idea: the **owner account** shares **one copy of a resource** with **accounts, OUs, the org or IAM roles / users**; consumers **use** it **without owning or duplicating it**. The owner keeps control; the consumer's IAM still decides which of its users can use it.

Part 1 - Core concepts

```
Owner account (e.g. Network account)
  Resource share "shared-network"
    Resources:   subnet-a, subnet-b, tgw-123, rslvr-rr-onprem
    Principals:  OU ou-workloads (or org o-xxx / account IDs / IAM roles)
    Permissions: AWSRAMDefaultPermissionSubnet (managed) or customer managed
    allowExternalPrincipals: false
Consumer accounts (Workloads OU)
  "Shared with me" -> use the resources (subject to their own IAM policies)
```

Concept	Meaning
Resource share	Container of **resources + principals + permissions**
Owner	Owns the resource, creates the share, **keeps control** (modify, delete, stop sharing)
Principals	**Account IDs**, **organization** (`o-`), **OUs** (`ou-`), **IAM roles / users** (some types), service principals (some types)
Managed permissions	**Actions consumers may perform**: **AWS managed** (default per type) or **customer managed** (subset of actions + conditions, versioned); **one per resource type per share**
Consumers	Use the resource; **their admins must grant IAM permissions**; effective access = RAM permission AND consumer IAM
Allow external principals	Share setting; **false = only principals inside the org**

Part 2 - Inside vs outside the organization

Mode	How	Invitations?
Sharing with Organizations enabled (`aws ram enable-sharing-with-aws-organization` from the **management account**)	Share with **org**, **OU** or members	**No invitations**; **new accounts in the OU / org get access automatically**
Not enabled	Share with account IDs	**Invitation** to accept (expires after about 7 days)
External accounts	Account IDs with `allowExternalPrincipals = true`	**Always an invitation**

- Some types are **org-only** - notably **VPC subnets**.
- OU / org shares are **dynamic**: accounts moving in get access, accounts leaving lose it.

Part 3 - Commonly shared resource types

Resource	Typical use
VPC subnets (VPC sharing)	App accounts launch EC2, RDS, Lambda, ALB **into a central network account's subnets**
Transit Gateway	Other accounts **attach their VPCs** to a central TGW
Route 53 Resolver rules	**Hybrid DNS**: forward `corp.example.com` to on-prem from all accounts; consumers **associate** rules with their VPCs
Resolver DNS Firewall rule groups / **Route 53 Profiles**	Central DNS security / configuration
Managed prefix lists	One CIDR list for **security groups / route tables** in every account; update once
Network Firewall policies / rule groups	Central firewall policy
VPC IPAM pools	Accounts allocate CIDRs from shared pools
VPC Lattice, **Cloud WAN**	Service networking, global network
License Manager configurations	Enforce licences across accounts
Capacity Reservations / Dedicated Hosts / placement groups	Share capacity
Aurora DB clusters	**Cross-account cloning** (prod clone in test account)
EC2 Image Builder components / recipes / images	Golden image artefacts
ACM Private CA	One private CA for many accounts
SSM parameters (advanced tier), Incident Manager contacts	Shared config / contacts
Glue Data Catalog / Lake Formation, CodeBuild, Outposts, Resource Groups, AppRegistry	Others

Not shared with RAM

Resource	How instead
S3, KMS, SNS, SQS, Lambda, ECR, Secrets Manager	**Resource-based policies** (for example `aws:PrincipalOrgID`)
AMIs, EBS / RDS snapshots	**Launch / restore permissions** (account, org or OU)
Service Catalog portfolios	**Portfolio sharing**
CloudFormation stacks	**StackSets** deploy copies
General access	**Cross-account IAM roles**

Part 4 - VPC sharing in detail

```
Network (owner) account                  App account A                 App account B
  VPC 10.0.0.0/16 + IGW + NAT + TGW att.   EC2, RDS, ALB in subnet-a     Lambda ENIs, EC2 in subnet-b
  route tables, NACLs, VPC endpoints       its own security groups       its own security groups
  shares subnet-a -> A, subnet-b -> B      (one VPC, same routing, private IPs reachable)
```

Who	Can	Can't
Owner	Manage **VPC, subnets, route tables, NACLs, IGW, NAT, VPC endpoints, TGW attachments, flow logs**; share / unshare; **see** participant ENIs	**Modify / delete participant resources** or their security groups
Participants	**Launch, manage and pay for their own resources**; **create their own security groups** (reference other SGs in the VPC by ID)	**Modify VPC-level resources**; **see / modify other participants' resources**; **re-share**; use the **owner's default SG**

- **Same organization only** (enable org sharing).
- **Default VPC subnets can't be shared.**
- **Use AZ IDs** (`use1-az1`), not AZ names - names map differently per account.
- **Billing**: participants pay for **their resources**; owner pays **VPC-level resources** (NAT, endpoints, TGW attachments).
- **Benefits**: **fewer VPCs**, **IP conservation**, **no peering / TGW between apps in the same VPC**, **central network governance** while keeping **account isolation** (IAM, billing, quotas).
- Compare: **VPC peering** (non-transitive, no overlapping CIDRs), **Transit Gateway** (hub routing), **PrivateLink** (expose one service).

Part 5 - Permissions, governance, monitoring

Managed permissions

- Default **AWS managed** permission per type (for example `AWSRAMDefaultPermissionSubnet`).
- **Customer managed permissions**: **fewer actions + conditions** (read-only prefix list), **versioned**.
- **Consumers still need IAM permissions** in their account.

RAM condition keys

Condition key	Use
`ram:RequestedAllowsExternalPrincipals`	**Block shares open to external accounts**
`ram:RequestedResourceType` / `ram:ResourceType`	Restrict shareable types
`ram:Principal`	Restrict who can receive shares
`ram:ResourceShareName`, `ram:PermissionArn`, `aws:ResourceTag`	Fine-grained control

SCP: no sharing outside the organization

```
{ "Effect": "Deny",
  "Action": ["ram:CreateResourceShare", "ram:UpdateResourceShare"],
  "Resource": "*",
  "Condition": { "Bool": { "ram:RequestedAllowsExternalPrincipals": "true" } } }
```

SCP: only the network account may share subnets / TGW

```
{ "Effect": "Deny",
  "Action": ["ram:CreateResourceShare", "ram:AssociateResourceShare"],
  "Resource": "*",
  "Condition": {
    "StringEquals": { "ram:RequestedResourceType": ["ec2:Subnet", "ec2:TransitGateway"] },
    "StringNotEquals": { "aws:PrincipalAccount": "111111111111" } } }
```

- Set `allowExternalPrincipals = false` on shares.
- **IAM Access Analyzer** reports resources shared outside the **zone of trust**.
- **CloudTrail** records RAM calls; **EventBridge** RAM events; **Config** records resources in each owning account.

Part 6 - Architecture patterns

Pattern	RAM role
Central networking	Share **subnets**, **TGW**, **prefix lists**, **Resolver rules**, **Network Firewall**, **IPAM pools** with OUs; Control Tower / AFT accounts get access via OU sharing
Hybrid DNS	**Resolver outbound endpoint + forwarding rules in network account, shared to all accounts**; VPCs associate rules
Golden images	Share **Image Builder** images / recipes (or AMIs via launch permissions)
Licensing	Share **License Manager** configurations
Test data	Share **Aurora cluster**, **clone** in test account
PKI	Share **ACM Private CA**
Capacity	Share **Capacity Reservations**

Part 7 - Exam traps

Trap	Truth
Duplicate VPCs per account and peer them	**VPC sharing**
VPC sharing with an external partner	**Same organization only**
Share default VPC subnets	**Not allowed**
Participant changes routes / NACLs	**Owner only**
Owner deletes participant's instance	**Can't**
Participant uses owner's default SG	**Not allowed**
Participant re-shares subnet	**Not allowed**
`us-east-1a` same in every account	**Use AZ IDs**
Org shares need invitations	**Not with org sharing enabled**
Add new accounts manually	**Share with OU / org**
Enable org sharing anywhere	**Management account**
External account doesn't see share	**Accept the invitation**
Consumer users get access automatically	**Consumer IAM must allow**
Limit consumer actions	**Customer managed permission**
Prevent sharing outside org	**SCP** `ram:RequestedAllowsExternalPrincipals` + `allowExternalPrincipals=false` + Access Analyzer
Only network account shares networking	**SCP** `ram:RequestedResourceType` **+** `aws:PrincipalAccount`
Share S3 / KMS with RAM	**Resource policies**
Share AMI / snapshot with RAM	**Launch / restore permissions**
Same corporate CIDRs in 50 accounts' SGs	**Shared prefix list**
All VPCs forward corp DNS on-prem	**Share Resolver rules**
All accounts attach to central TGW	**Share TGW**
Who pays NAT in shared VPC	**Owner**

Part 8 - Hands-on lab (about 45 to 60 minutes, 2 accounts in a test org)

Lab 1 - Enable org sharing

Management account: RAM -> Settings -> **Enable sharing with AWS Organizations** (or `aws ram enable-sharing-with-aws-organization`).

Lab 2 - VPC sharing

1. Network account: VPC `10.20.0.0/16`, two private subnets (note **AZ IDs**), route table (skip NAT to save cost).
2. **Create resource share** `shared-subnets`: both subnets, principal = participant account (or OU), external principals off, default permission.
3. Participant: **Shared with me** shows subnets; **create a security group** in the shared VPC; **launch a t3.micro** into a shared subnet.
4. Participant: edit route table / NACL = **denied**; default SG = **not allowed**. Owner: sees the ENI but **can't terminate** the instance.

Lab 3 - Prefix list with customer managed permission

1. Owner: managed prefix list `corp-ranges` (`10.0.0.0/8`, `192.168.0.0/16`).
2. **Customer managed permission** allowing only read / describe; share the prefix list with it.
3. Participant: reference it in an SG rule (works); modify it (denied). Owner adds a CIDR: participant SG picks it up.

Lab 4 - Governance

1. SCP denying `ram:CreateResourceShare` / `UpdateResourceShare` when `ram:RequestedAllowsExternalPrincipals` = true on the workload OU; creating an external share = **denied**.
2. **Access Analyzer** (org zone of trust): review external-sharing findings.
3. Optional: external share shows **pending** until accepted; optional shared **Resolver rule** association (outbound endpoint costs extra).

Cleanup: terminate the instance, delete its SG, shares, customer managed permission, prefix list, VPC; detach the SCP.

Part 9 - Check yourself

Questions

1. Three parts of a resource share, and which principals?
2. What changes with sharing with Organizations, and where is it enabled?
3. How does sharing with an external account work?
4. VPC sharing: what does the owner manage vs participants?
5. Three things participants can't do in a shared VPC?
6. Can subnets be shared outside the org, or default subnets?
7. Why AZ IDs instead of names?
8. Who pays for what in a shared VPC?
9. Consumer sees a shared resource but developers can't use it - why?
10. Let consumers only read a shared prefix list?
11. Prevent sharing outside the organization?
12. All VPCs in 40 accounts forward corp.example.com to on-prem DNS?
13. SGs in all accounts allow the same corporate CIDRs, updated centrally?
14. S3 bucket, AMI, Transit Gateway, KMS key - which via RAM, and the others?
15. Benefits of VPC sharing over a VPC per account with peering?

Answers

1. **Resources, principals, permissions**; account IDs, org, OUs, IAM roles / users (some types), service principals.
2. **No invitations**, **new accounts in OU automatically**; enabled from the **management account**.
3. `allowExternalPrincipals = true`; external account **accepts the invitation** before it expires.
4. **Owner**: VPC, subnets, routes, NACLs, IGW / NAT, endpoints, TGW attachments; **participants**: their resources + SGs.
5. Modify routes / NACLs / subnets; see / modify others' resources; re-share; use owner's default SG.
6. **No** and **no**.
7. AZ names map to different physical AZs per account; **AZ IDs** are consistent.
8. Participants pay **their resources**; owner pays **NAT, endpoints, TGW attachments**.
9. **Consumer IAM** must grant access (RAM permission AND IAM).
10. **Customer managed permission** with read / describe only.
11. **SCP** on `ram:RequestedAllowsExternalPrincipals` = true + `allowExternalPrincipals=false` + **Access Analyzer**.
12. **Resolver outbound endpoint + forwarding rule** in network account, **shared via RAM**, each VPC associates it.
13. **Shared managed prefix list**.
14. **TGW** via RAM; S3 and KMS via **resource policies**; AMI via **launch permissions**.
15. **Fewer VPCs, IP conservation, no peering between apps, central network control, account isolation**.

Quick memory summary

- **RAM** = share **one resource** via a **resource share** (resources + principals + **managed permissions**, AWS or customer managed); **consumer IAM still applies**.
- **Org sharing** (management account) = no invitations, OU / org shares include **new accounts**; external = **invitation**, `allowExternalPrincipals`.
- **Shareable**: **subnets**, **TGW**, **Resolver rules**, **prefix lists**, Network Firewall, IPAM, Lattice, License Manager, Capacity Reservations, Aurora (clone), Image Builder, Private CA, advanced SSM parameters.
- **Not RAM**: S3 / KMS / SNS / SQS / Lambda / ECR / Secrets Manager (resource policies), AMIs / snapshots (launch permissions), Service Catalog (portfolio sharing).
- **VPC sharing**: **same org**, no default subnets, owner = VPC level, participants = resources + SGs, **AZ IDs**, owner pays NAT / endpoints.
- **Govern**: SCP `ram:RequestedAllowsExternalPrincipals`, `ram:RequestedResourceType`, **Access Analyzer**, CloudTrail / EventBridge.